PharmaX Top 10 Security Risk Assessment Report

NIST SP 800-30 | RISK ASSESSMENT

CYBERSECURITY | THREAT ANALYSIS

RISK MANAGEMENT | TOP 10

PHARMAX | PHARMACEUTICAL

Course	SWE 267P
Quarter	Spring 2026
Student	Zhenyu Song

This report presents a **high-level qualitative Top 10 Security Risk Assessment** for PharmaX, following the NIST SP 800-30 methodology. It identifies threat events, assesses likelihood and impact, and provides actionable recommendations to improve PharmaX's security posture.

Table of Contents

- PharmaX Top 10 Security Risk Assessment Report
  - Table of Contents
  - 1. Introduction
    - Why This Assessment Is Needed
    - 2. Assumptions
  - 3. Findings and Recommendations
    - Risk Summary
    - Finding 1: Phishing and Spear Phishing Attacks
    - Finding 2: Ransomware Deployment
    - Finding 3: Insider Threat and Unauthorized Consultant Access
    - Finding 4: Supply Chain Compromise via CodeX CI/CD Pipeline
    - Finding 5: Exploitation of Unpatched Vulnerabilities
    - Finding 6: Data Exfiltration of Medical Research IP
    - Finding 7: VPN Compromise and Remote Worker Exploitation
    - Finding 8: Third-Party Provider Breach (CloudX, HostingX, SecX)
    - Finding 9: Physical Security Breach and Document Theft
    - Finding 10: DDoS Attack or Infrastructure Failure Affecting Cloud Connect
    - 4. Conclusion
  - References

1. Introduction

This report is a high-level qualitative security risk assessment for PharmaX. The goal is to identify and prioritize the top 10 security risks and provide recommendations for each one. The methodology follows NIST SP 800-30, using threat events from Table E-2, threat sources from Appendix D, and the qualitative risk scales from Appendix G (Likelihood), Appendix H (Impact), and Appendix I (Risk Determination).

Why This Assessment Is Needed

PharmaX has never done a security risk assessment before. The company's security maturity is low, and security awareness among employees and management is weak. They handle sensitive customer data and proprietary medical research data, but there is no formal documentation of critical assets or data flows. A penetration test was done in the past by an external company, but the report was not taken seriously by management and ended up sitting on a shelf.

On top of that, PharmaX relies heavily on several third-party companies (CloudX, HostingX, SecX, CodeX) for critical infrastructure and development. About half the workforce works remotely. All of this creates a large and complex attack surface that needs to be assessed.

2. Assumptions

Since the assignment description does not cover every detail of PharmaX's environment, the following assumptions are made. These are needed to properly evaluate the risks and none of them contradict the information given in the assignment.

1. **No formal security policies exist.** There are no documented incident response plans, acceptable use policies, data classification policies, or business continuity/disaster recovery plans.
2. **No security awareness training.** Employees and external consultants have not gone through any structured cybersecurity training program.
3. **The VPN does not use multi-factor authentication (MFA).** Given the low security maturity, it is assumed that remote workers connect through the CloudX-managed VPN with just a username and password.

4. **No formal patch management and no EDR deployed.** There is no automated patching process for servers, workstations, or network devices, and no endpoint detection and response (EDR) or advanced endpoint protection beyond basic antivirus in the firewall.
5. **External consultants and some executives use personal, unmanaged laptops, and there is no formal onboarding/offboarding process.** These devices have no enforced endpoint security or compliance checks. When employees or consultants leave, there is no guaranteed process for revoking their access promptly.
6. **The CI/CD pipeline managed by CodeX has access to PharmaX source code.** Since CodeX provides and manages the entire development pipeline, they could potentially introduce code changes without PharmaX oversight.
7. **No third-party risk management program.** PharmaX does not require SOC 2 reports, ISO 27001 certifications, or any formal security assurance from CloudX, HostingX, SecX, or CodeX.
8. **SecX only monitors firewall traffic.** They do not have visibility into internal network traffic, endpoint activity, or application-level events.
9. **Medical research data is treated as trade secrets and high-value intellectual property.** This data would be extremely valuable to competitors and nation-state actors.
10. **Physical security at office locations is basic.** There is no mention of badge access systems, CCTV, or visitor management — it is assumed that offices rely on standard door locks and network equipment (routers, switches, Wi-Fi APs) is not locked in separate closets or cabinets.

3. Findings and Recommendations

Risk Summary

#	Threat Event	Likelihood	Impact	Risk
1	Phishing / Spear Phishing	High	High	**High**
2	Ransomware	High	Very High	**Very High**
3	Insider Threat / Consultant Access	Moderate	High	**Moderate**
4	Supply Chain Compromise via CodeX	Moderate	Very High	**High**
5	Unpatched Vulnerabilities	High	High	**High**
6	Data Exfiltration of Research IP	Moderate	Very High	**High**

#	Threat Event	Likelihood	Impact	Risk
7	VPN / Remote Worker Compromise	High	Moderate	**Moderate**
8	Third-Party Provider Breach	Moderate	Very High	**High**
9	Physical Security Breach	Low	Moderate	**Low**
10	DDoS on Cloud Connect	Moderate	High	**Moderate**

Finding 1: Phishing and Spear Phishing Attacks

Threat Event (Table E-2): Craft phishing attacks; Craft spear phishing attacks

All 160 employees and consultants use Outlook email and web browsers with Internet access. Since there is no security awareness training (Assumption #2) and employees have weak security awareness, phishing emails are very likely to trick someone into giving up credentials or clicking malicious links. Spear phishing targeting executives is also a concern since the board has little security experience.

Threat Sources: External adversaries, organized crime, opportunistic attackers

Vulnerability:

- No security awareness training program for employees or consultants.
- Email filtering relies only on CloudX firewall's basic anti-spam.
- No phishing simulation exercises have ever been conducted.

Likelihood: High — Phishing is the most common attack vector, and PharmaX has zero training to defend against it.

Impact: High — Stolen credentials could give attackers access to customer PII, payment data, and medical research IP. This could lead to data breaches, regulatory fines, and reputation damage.

Overall Risk: High

Recommendations:

1. Roll out mandatory security awareness training for all employees and consultants, with a focus on recognizing phishing emails.
2. Deploy an email security gateway with advanced threat protection (sandboxing, URL analysis).

3. Run phishing simulation exercises at least quarterly.
4. Implement MFA on email and all critical systems.

Finding 2: Ransomware Deployment

Threat Event (Table E-2): Deliver known malware to internal organizational information systems; Deliver targeted malware for control of internal systems and exfiltration of data

Attackers could deliver ransomware through email or compromised websites to encrypt PharmaX's data and demand payment. Since there is no EDR or formal patch management (Assumption #4) and no incident response plan (Assumption #1), PharmaX would be highly vulnerable and poorly prepared to respond.

Threat Sources: Organized crime, opportunistic attackers

Vulnerability:

- No EDR or advanced endpoint protection deployed.
- Patch management is ad hoc, leaving known vulnerabilities open.
- No incident response plan or disaster recovery plan exists.
- Backup server may not be configured for offline/immutable backups.

Likelihood: High — Pharma companies are high-value targets for ransomware. The lack of endpoint protection and patching makes a successful attack very likely.

Impact: Very High — Ransomware could encrypt medical research data, customer records, and business systems across both data centers. Without an incident response or DR plan, recovery could take weeks and cost millions.

Overall Risk: Very High

Recommendations:

1. Deploy EDR across all company-managed endpoints and servers.
2. Set up immutable, offline backups with regular tested restores.
3. Create and test an incident response plan with ransomware-specific playbooks.
4. Develop a business continuity and disaster recovery (BC/DR) plan.

Finding 3: Insider Threat and Unauthorized Consultant Access

Threat Event (Table E-2): Obtain unauthorized access; Conduct insider-based social engineering to obtain information

The 20 external consultants use personal, unmanaged laptops and there is no formal process for revoking access when people leave (Assumption #5). There are also no regular access reviews or privileged access management controls. This means someone could have more access than they need, or keep access after they should not have it anymore.

Threat Sources: Trusted insiders, privileged insiders, external consultants

Vulnerability:

- External consultants use unmanaged personal laptops.
- No formal access provisioning/deprovisioning process.
- No privileged access management or regular access reviews.

Likelihood: Moderate — Most people will not act maliciously, but the lack of controls makes accidental or intentional data exposure a real possibility.

Impact: High — Unauthorized access to medical research IP or customer data could cause significant financial and legal damage.

Overall Risk: Moderate

Recommendations:

1. Implement role-based access control (RBAC) and least-privilege principles.
2. Set up a formal onboarding/offboarding process with immediate access revocation upon departure.
3. Require all devices accessing PharmaX systems to meet minimum security standards (endpoint protection, disk encryption), enforced via MDM or NAC.
4. Conduct quarterly access reviews for all user accounts.

Finding 4: Supply Chain Compromise via CodeX CI/CD Pipeline

Threat Event (Table E-2): Compromise design, manufacture, and/or distribution of information system components; Insert targeted malware into organizational information systems

CodeX in Vietnam provides and manages PharmaX's entire CI/CD pipeline for application development. Since PharmaX has no oversight over this pipeline (Assumption #6) and no third-party risk management program (Assumption #7), an attacker could compromise CodeX's infrastructure to inject malicious code, or a CodeX insider could introduce a backdoor.

Threat Sources: Nation-state actors, organized crime, malicious or careless CodeX insiders

Vulnerability:

- CI/CD pipeline is fully managed by CodeX with no PharmaX oversight.
- No third-party risk management or vendor security assessments.
- No code review, SAST, or software composition analysis in place.

Likelihood: Moderate — Supply chain attacks on CI/CD pipelines are becoming more common. The complete lack of oversight makes this a realistic concern.

Impact: Very High — Malicious code shipped in PharmaX products could affect customers, destroy the company's reputation, and create massive legal liability.

Overall Risk: High

Recommendations:

1. Require CodeX to provide SOC 2 Type II or ISO 27001 certification as part of a third-party risk management program.
2. Implement code signing and integrity checks for all CI/CD pipeline artifacts.
3. Perform code reviews and run SAST/DAST on all code delivered by CodeX.
4. Add security requirements and right-to-audit clauses to the CodeX contract.

Finding 5: Exploitation of Unpatched Vulnerabilities

Threat Event (Table E-2): Exploit recently discovered vulnerabilities; Exploit vulnerabilities on internal organizational information systems

PharmaX uses Microsoft Office, Edge/Chrome browsers, internal mail servers, domain controllers, and specialized pharma software. Without formal patch management (Assumption #4), critical vulnerabilities could remain unpatched for a long time. The outdated infrastructure documentation means the IT team might not even know about all the systems that need patching.

Threat Sources: External adversaries, organized crime, nation-state actors

Vulnerability:

- No formal or automated patch management process.
- Outdated infrastructure documentation — IT may not know all systems needing patches.
- No vulnerability scanning program.

Likelihood: High — Unpatched systems are easy to find with automated scanners. Without a process, patches will not be applied in time.

Impact: High — Exploiting a vulnerability could give attackers initial access, leading to data breaches, ransomware, or operational disruption.

Overall Risk: High

Recommendations:

1. Implement automated patch management for all OSes, applications, and network devices.
2. Start a vulnerability management program with monthly scans and remediation SLAs.
3. Maintain an up-to-date asset inventory so nothing falls through the cracks.

Finding 6: Data Exfiltration of Medical Research IP

Threat Event (Table E-2): Obtain sensitive information via exfiltration; Compromise organizational information systems to facilitate exfiltration of data/information

PharmaX's medical research data is high-value IP (Assumption #9). Attackers could use compromised credentials or malware to find and steal this data. Since SecX only monitors firewall traffic (Assumption #8), internal lateral movement and data staging would go completely undetected. There is no data classification, no DLP, and no network segmentation between research and general business systems.

Threat Sources: Nation-state actors, competitors, organized crime

Vulnerability:

- No data classification or DLP controls.
- No network segmentation between research and business systems.
- SecX monitors only firewall traffic — no internal visibility.

Likelihood: Moderate — Pharmaceutical IP is a well-known target for espionage. PharmaX is mid-sized, which reduces targeting likelihood somewhat, but the lack of controls makes exfiltration easy once inside.

Impact: Very High — Losing proprietary research data could destroy PharmaX's competitive advantage and lead to massive financial losses.

Overall Risk: High

Recommendations:

1. Implement data classification to identify where sensitive data lives.
2. Deploy network segmentation to isolate research systems from the general business network.
3. Set up a SIEM with monitoring beyond just firewall traffic.
4. Deploy DLP tools to detect unauthorized data transfers.

Finding 7: VPN Compromise and Remote Worker Exploitation

Threat Event (Table E-2): Exploit split tunneling; Exploit known vulnerabilities in mobile systems (e.g., laptops)

About 80 people (50% of 160) work remotely and connect via CloudX's VPN. Without MFA on the VPN (Assumption #3), a stolen password is all an attacker needs to get on the network. Executives and consultants using personal laptops (Assumption #5) could also be compromised through their insecure home networks or split tunneling.

Threat Sources: External adversaries, opportunistic attackers

Vulnerability:

- No MFA on VPN connections.
- Personal laptops are unmanaged with no compliance checks.
- Split tunneling may be enabled, exposing dual-network connections.

Likelihood: High — Large remote workforce + no MFA + personal devices = very attractive attack vector.

Impact: Moderate — VPN compromise gives access to the Cloud Connect network, but the attacker still needs to escalate privileges to reach high-value targets. Still, it is a dangerous initial foothold.

Overall Risk: Moderate

Recommendations:

1. Implement MFA on all VPN connections immediately — this is a quick, high-impact fix.
2. Disable split tunneling to prevent dual-network exposure.
3. Deploy NAC to verify device compliance before granting VPN access.
4. Require company-managed laptops or enforce minimum device security standards via MDM.

Finding 8: Third-Party Provider Breach (CloudX, HostingX, SecX)

Threat Event (Table E-2): Exploit multi-tenancy in a cloud environment; Conduct supply chain attacks targeting critical hardware, software, or firmware

PharmaX depends heavily on CloudX (networking, firewalls, VPN), HostingX (data centers), and SecX (security monitoring). A breach at any of these providers could directly compromise PharmaX. Since there is no third-party risk management (Assumption #7) and no contractual security requirements, PharmaX has no way to verify or influence these providers' security posture.

Threat Sources: Nation-state actors, organized crime, negligent provider employees

Vulnerability:

- No third-party risk management or vendor security assessments.
- No contractual security requirements, SLAs, or right-to-audit clauses.
- CloudX's "private secure network" claim cannot be independently verified.

Likelihood: Moderate — Third-party breaches happen regularly in the industry, and PharmaX has zero visibility into its providers' controls.

Impact: Very High — A CloudX breach could expose the entire network. A HostingX breach could compromise both data centers. A SecX compromise could blind PharmaX to ongoing attacks.

Overall Risk: High

Recommendations:

1. Build a third-party risk management (TPRM) program with annual security assessments for all critical vendors.

2. Require SOC 2 Type II reports or equivalent from CloudX, HostingX, and SecX.
3. Add incident notification obligations and right-to-audit clauses to vendor contracts.
4. Develop contingency plans for provider failure.

Finding 9: Physical Security Breach and Document Theft

Threat Event (Table E-2): Exploit physical access of authorized staff to gain access to organizational facilities; Compromise critical information systems via physical access

PharmaX has three office locations and still keeps printed files in filing cabinets. An attacker who gains physical access — through tailgating or social engineering — could steal documents, access unattended workstations, or plug in rogue devices on the network. Network equipment like routers and Wi-Fi access points in offices may also be physically accessible.

Threat Sources: Competitors, social engineers, disgruntled former employees

Vulnerability:

- Printed documents in filing cabinets with basic physical security.
- Unattended workstations may not auto-lock.
- Network equipment in offices may be physically accessible.

Likelihood: Low — Physical attacks need the attacker to be on-site, which limits the threat pool significantly.

Impact: Moderate — Stolen documents could contain business or research info. Physical access to network gear could enable persistent compromise. But most sensitive data is electronic, limiting the impact of document theft alone.

Overall Risk: Low

Recommendations:

1. Implement a clean desk policy and lock sensitive documents in cabinets.
2. Enforce automatic screen lock after 5 minutes of inactivity.
3. Set up a visitor management process with sign-in and escort requirements.
4. Speed up the transition to fully electronic documentation.

Finding 10: DDoS Attack or Infrastructure Failure Affecting Cloud Connect

Threat Event (Table E-2): Conduct Distributed Denial of Service (DDoS) attacks; Conduct targeted Denial of Service (DoS) attacks
Threat Event (Table E-3 — Non-Adversarial): Infrastructure failure/outage (telecommunications, electrical power)

All PharmaX offices connect through Cloud Connect as the sole network backbone. This connectivity could be disrupted either by an adversarial DDoS attack or by a non-adversarial event such as a telecommunications outage, power failure at a data center, or equipment malfunction at CloudX. Either way, the result is the same — all offices lose connectivity to both data centers, stopping email, file access, and even phone calls (since public telephony routes through the primary data center). There is no redundant connectivity and no business continuity plan.

Threat Sources (Adversarial): Hacktivists, competitors, organized crime (extortion)
Threat Sources (Non-Adversarial): Infrastructure failure, equipment aging, power outage, natural disaster

Vulnerability:

- Cloud Connect is the sole network backbone — single point of failure.
- DDoS mitigation capabilities of CloudX are unknown.
- No redundant connectivity path exists.
- No business continuity plan addresses network outage scenarios.

Likelihood: Moderate — DDoS attacks are cheap and common, and non-adversarial outages (power failures, equipment issues) happen routinely in the industry. The single point of failure makes any disruption event impactful.

Impact: High — Total network outage would halt all business operations across all locations simultaneously.

Overall Risk: Moderate

Recommendations:

1. Work with CloudX to assess and improve DDoS mitigation capabilities.
2. Evaluate backup network connectivity (secondary ISP or SD-WAN) to eliminate the single point of failure.
3. Develop a business continuity plan for prolonged network outages.

4. Ensure CloudX SLAs include uptime guarantees and DDoS response commitments.

4. Conclusion

PharmaX faces serious security risks driven by its low security maturity and heavy dependence on third-party providers with no oversight. The most critical risk is ransomware (Very High), followed by several High-risk findings including phishing, supply chain attacks, unpatched vulnerabilities, data exfiltration, and third-party breaches.

The recommended priority order is:

1. **Immediate:** MFA on VPN, security awareness training, patch management basics.
2. **Short-term:** EDR deployment, incident response plan, third-party risk management program.
3. **Long-term:** SIEM, data classification, network segmentation, formal security governance with board-level oversight.

References

- NIST Special Publication 800-30 Rev. 1: Guide for Conducting Risk Assessments
- NIST SP 800-30, Appendix D: Threat Sources (Table D-2, D-3)
- NIST SP 800-30, Appendix E: Threat Events (Table E-2, E-3)
- NIST SP 800-30, Appendix G: Likelihood of Occurrence (Table G-2, G-3)
- NIST SP 800-30, Appendix H: Impact (Table H-3)
- NIST SP 800-30, Appendix I: Risk Determination (Table I-2, I-3)